

Log Analysis & Incident Response — POC Report

Intern Name: Ruby Kannaujiya

Intern ID: 309

Tool Name / Topic

Log Analysis & Incident Response — tools: rsyslog, journalctl, /var/log/*, auditd, tcpdump, suricata, Splunk, Elasticsearch/Logstash/Kibana (ELK), OSQuery, Volatility (memory), yara, grep/awk/sed, jq.

History

Log analysis and IR evolved from simple sysadmin troubleshooting into a formal discipline used by SOC teams, DFIR (digital forensics & incident response) groups, and law enforcement. Modern IR couples log/timeline analysis with endpoint and network telemetry to discover, contain, and remediate incidents quickly.

Description

This week focuses on collecting logs, creating timelines, detecting suspicious activity, triaging alerts, and performing an incident response workflow. The PoC demonstrates practical log analysis techniques on Linux/Windows hosts and simple SIEM queries for Splunk/ELK. All steps are safe, evidence-preserving, and reproducible in lab environments.

Legal / Ethical Note: Only collect and analyze logs from systems you own or have explicit permission to investigate.

What Is This Topic About?

- Locating and parsing logs (system, auth, application, network).
- Building an event timeline to understand attacker actions.
- Using SIEM tools (Splunk/ELK) to search and visualize events.
- Performing containment, eradication, and recovery with documented steps.
- Producing an IR report with IOC extraction and mitigation.

Key Characteristics / Features

- Emphasis on evidence preservation (read-only collection when possible).
- Use of command-line and SIEM queries for detection.
- Timeline construction from logs, network captures, and endpoint data.
- Integration with threat intelligence (IOCs).
- Automation with scripts and saved SIEM searches.

Types / Modules / Data Sources Covered

- **System logs:** `/var/log/syslog`, `/var/log/auth.log`, `journalctl`
- **Application logs:** web server logs (`/var/log/nginx/*.log`), DB logs
- **Windows logs:** Event Viewer (Security, System, Application) — exported EVTX
- **Network telemetry:** `tcpdump` pcap, IDS alerts (Suricata)
- **Endpoint telemetry:** process lists, autoruns, `osquery` results
- **Memory analysis:** memory dump + volatility
- **Malware/IOC scanning:** `yara`, `clamscan`, `virustotal` hashes

How Will This Help?

- Detect intrusions earlier via log indicators.
- Build a reliable timeline for forensic reporting.
- Provide repeatable containment & remediation steps.
- Produce artifacts (IOCs) usable in prevention (blocklists, SIEM rules).
- Train SOC analysts in practical triage.

Detailed POC — Step-by-step (Linux & Splunk / ELK examples)

Lab note: Use a copy of logs or take snapshots. When possible, perform forensic imaging (dd) and work on copies. Timestamp every action.

A. Initial Triage — Finding Suspicious Indicators

Common signs to look for:

- Repeated failed logins / brute force attempts
- New user creation or privilege changes
- Unusual processes or scheduled tasks (cron)
- Unexpected network connections to rare IPs or known-bad IOCs
- Web server unusual 500/401 spikes or odd endpoints

Commands (Linux):

```
# Last logins and failed attempts
last -a | head
grep "Failed password" /var/log/auth.log | tail -n 50
```

```
# Recent sudo usage
grep "sudo" /var/log/auth.log | tail -n 50
```

```
# New users created recently (compare with baseline)
```

```
awk -F: '$3>=1000{print $1,$3}' /etc/passwd
```

```
# Running processes
```

```
ps aux --sort=-%mem | head
```

```
# Check cron entries for suspicious scripts
```

```
cat /etc/crontab
```

```
ls -la /var/spool/cron/crontabs
```

```
# Search webserver logs for odd URIs or POSTs
```

```
grep "POST" /var/log/nginx/access.log | tail -n 50
```

Windows triage (export EVTX then use built-in or tools):

- Use `wevtutil qe Security /rd:true /f:text /c:200` or export logs via Event Viewer.
- Look for Event IDs: 4625 (failed logon), 4624 (successful logon), 4688 (process creation).

B. Collect Evidence (preserve, copy, hash)

```
# Create directory for evidence
```

```
mkdir -p /tmp/IR_collect/$(date +"%F_%T")
```

```
# Copy important logs (read-only)
```

```
cp /var/log/auth.log /tmp/IR_collect/
```

```
cp /var/log/syslog /tmp/IR_collect/
```

```
cp /var/log/nginx/access.log /tmp/IR_collect/
```

```
# Hash files for chain of custody
```

```
sha256sum /tmp/IR_collect/* > /tmp/IR_collect/hashes.txt
```

Document who collected what, when, and why.

C. Build Timeline (combine logs)

Option 1 — simple chronological merge (Linux logs):

```
cat /tmp/IR_collect/syslog /tmp/IR_collect/auth.log | sort >
/tmp/IR_collect/merged_timeline.txt
```

Option 2 — use log2timeline / plaso (for advanced timeline building)

```
log2timeline.py /tmp/IR_collect/plaso_output /path/to/logs
psort.py -o l2tcsv /tmp/IR_collect/plaso_output > timeline.csv
```

D. Network Forensics (pcap) — capture and inspect

Capture (live):

```
sudo tcpdump -i eth0 -w /tmp/IR_collect/suspect_traffic.pcap host
1.2.3.4
```

Inspect with tshark / Wireshark:

```
tshark -r /tmp/IR_collect/suspect_traffic.pcap -q -z conv,ip
# Extract HTTP requests containing suspicious URI
tshark -r file.pcap -Y 'http.request' -T fields -e http.request.uri
```

E. Malware & IOC Scanning

- Extract file hashes from logs or collected binaries:

```
sha256sum /path/to/suspect_file > /tmp/IR_collect/filehash.txt
# Check locally with YARA or VirusTotal API
yara -r /path/to/rules.yar /tmp/IR_collect/suspect_file
```

F. SIEM Examples — Splunk & ELK Query Samples

Splunk (examples assume logs indexed with sourcetypes auth, syslog, nginx):

1. Failed SSH logins (time window: last 24h)

```
index=* sourcetype=auth "Failed password" | stats count by src_ip, user | sort -count
```

2. Suspicious process creation (Windows events)

```
index=windows EventCode=4688 | stats count by NewProcessName, AccountName | where count>5
```

3. Webserver POST spikes to /upload

```
index=* sourcetype=nginx access.log uri="/upload" | timechart count by status
```

4. Known IOC hit (match IP)

```
index=* (src_ip="1.2.3.4" OR dest_ip="1.2.3.4") | table _time, host, src_ip, dest_ip, uri
```

Elasticsearch / Kibana (KQL examples):

1. Failed SSH (Kibana)

```
event.dataset: "auth" and message: "Failed password"
```

2. Process creation spikes (Windows)

```
event.code:4688 and process.name: "*cmd.exe"
```

3. Suspicious outbound connections (by geo)

- Visualize destination.ip and apply ip.geo filter in Kibana Maps.

G. Incident Response Playbook (step-by-step)

1. Preparation

- a. Baseline logs, backups, detection rules ready.

2. Identification

- a. Triage alerts, confirm compromise vs false positive.
- b. Example: multiple Failed password then Accepted password from same IP → suspicious.

3. Containment

- a. Short-term: block malicious IPs in firewall (ufw deny from 1.2.3.4), isolate host from network.
- b. Long-term: rotate credentials, patch services, disable compromised accounts.

4. Eradication

- a. Remove malware, kill persistence mechanisms (malicious cronjobs, systemd units).
- b. Re-image host if integrity is uncertain.

5. Recovery

- a. Restore services from verified backups, monitor closely for recurrence.

6. Lessons Learned

- a. Update detection rules, hardening checklist, and patch management timelines.

7. Reporting

- a. Produce IR report: timeline, IOCs, root cause, impact, remediation steps, evidence hashes, screenshots.

H. Example IR Scenario — PoC Walkthrough (simple, reproducible)

Scenario: Suspicious login followed by suspicious process and outbound connection.

1. `grep "Accepted password" /var/log/auth.log` → find userX logged in from IP 203.0.113.45 at 2025-09-12T14:01:02.
2. `grep "sshd" /var/log/syslog | grep "203.0.113.45"` → confirm session creation.

3. `ps aux --sort=-%mem | grep suspicious_process` on host → find `curl` running a script contacting `malicious.com`.
4. `tcpdump -nn -r /tmp/IR_collect/suspect_traffic.pcap` → extract HTTP requests to `malicious.com`.
5. Hash downloaded binary, check with YARA/VT.
6. Contain: `ufw deny from 203.0.113.45`, disable userX, snapshot VM for deeper analysis.
7. Eradicate: remove malicious files, clean cron, re-image host if needed.
8. Recover: restore from backup, change credentials, monitor with new SIEM rule.

PoC Images (placeholders — add screenshots)

- `grep` outputs showing failed → accepted login sequence.
- Splunk search screenshot showing repeated failed logins by IP.
- Wireshark view of suspicious HTTP POST to `malicious.com`.
- Timeline CSV from `log2timeline` displayed in Excel.
- YARA match output and hash comparison with VT.

15-Liner Summary

1. Preserve evidence: copy logs, hash files.
2. Start with triage: failed logins, new users, unexpected processes.
3. Build a timeline from combined logs.
4. Use `tcpdump`/pcap for network context.
5. Use YARA/virus scanners for file analysis.
6. Use Splunk/ELK for large-scale searching & visualization.
7. Contain quickly (block IPs, isolate hosts).
8. Eradicate persistence (cron, systemd, services).
9. Reimage if integrity doubtful.
10. Recover from verified backups.
11. Update detection rules and policies.
12. Document chain-of-custody and actions.
13. Share IOCs with stakeholders (and blocklists).

14. Test incident playbooks regularly.
15. Keep logs centralized and retained per policy.

Time to Use / Best Case Scenarios

- Immediately after an alert (IDS/SIEM) or suspicious user report.
- Post-breach containment and analysis.
- Tabletop exercises and SOC training.
- For compliance evidence gathering (audit).

When to Use During Investigation

- When a host shows anomalous behavior (new outbound traffic, process).
- Following Phishing that led to credential use.
- When indicators point to lateral movement.
- To validate scope of an intrusion across environment.

Best Person to Use & Required Skills

User: SOC Analyst / DFIR Investigator / Forensic Specialist

Skills Required:

- Comfort with shell (bash), Windows event logs, and SIEM query languages.
- Familiarity with network captures (TCP/IP).
- Knowledge of forensic best practices (imaging, hashing).
- Ability to interpret timestamps/timezones and correlate events.

Flaws / Suggestions to Improve

- Log coverage gaps hinder investigation (enable more verbose logging where safe).
- Time synchronization issues (NTP misconfigured) complicate timelines — ensure NTP.
- Large volumes of logs require SIEM; manual parsing is slow.
- Encrypted traffic without TLS termination points reduces visibility.
- Endpoint telemetry gaps (no EDR) reduce detection capability.

Good About This Topic (Why Learn It)

- High impact: good IR reduces dwell time and damage.
- Skills transferable across enterprises and cloud.
- Teaches evidence handling and reporting discipline.
- Enables creation of detection rules and prevention measures.
- Clear, repeatable procedures improve readiness.

Remediation / Hardening Checklist (Short)

- Centralize logs (rsyslog/Fluentd → ELK/Splunk) and retain per policy.
- Enable auditd for critical hosts and sensitive directories.
- Ensure NTP is configured and logs use UTC.
- Deploy endpoint detection (EDR) and network IDS (Suricata).
- Harden SSH (disable root login, enforce keys, fail2ban).
- Enforce MFA for remote access and admin accounts.
- Block known malicious IPs at perimeter and update blocklists.
- Test IR playbooks and perform regular tabletop exercises.
- Keep backups offline and tested for restore.